Datenschutzbericht — {{COMPANY_NAME}} (Fräsdienst-Service E. Feind GmbH)

Domain: fraesdienst-feind.de **Berichtstyp:** Zusammenfassender Datenschutz-/DSGVO-Statusbericht mit Maßnahmen, Vorlagen und Roadmap **Zielgruppe:** Geschäftsführung, Datenschutzbeauftragte(r) (intern/extern), IT-Verantwortliche, ggf. Aufsichtsbehörde (LDA Brandenburg) **Erstellt von:** David Halko (Marketing & Eventmanagement) mit KI-Unterstützung **Berichtsdatum:** 28.10.2026 **Version:** 1.5 (Entwurf) **Änderungsvermerk v1.5 (28.10.2026):** Mitgelieferte **`.env`-Vorlage** (`.env.example` im Repository-Wurzelverzeichnis, nur leere Platzhalter): Alle im Bericht referenzierten Umgebungsvariablen (Abschnitt 0, Anhang R) sind dort als ausfüllbare Vorlage hinterlegt. Abschnitt 0 und der Faktenlage-Hinweis verweisen jetzt auf diese Datei; das Platzhalter-Verzeichnis (Anhang R) nennt die zugehörigen `.env`-Schlüssel. Versionsangabe in der Schlusszeile korrigiert (stand noch auf 1.2). **Änderungsvermerk v1.4 (01.10.2026):** Abschnitt 12.1 (Kartenansicht im internen Feind Cockpit: Kachelanbieter, Einwilligung, lokal eingebettete Schrift) und Zeile „Kartenkachel-Anbieter“ in 7.1 ergänzt. Alle Fassungen (MD, HTML, DOCX, PDF) aus der Markdown-Quelle neu erzeugt; dabei im HTML „Datenschutzbeauftragte(r)“ korrigiert (stand dort als „®“) und in v1.3 verlorene Hervorhebungen wiederhergestellt. **Änderungsvermerk v1.3 (21.09.2026):** Unternehmensprofil korrigiert (Kaltfräsarbeiten im Straßen-/Tiefbau statt CNC-Fertigung), Standorte Lübben (Brandenburg) und Wittenburg (Mecklenburg-Vorpommern) sowie zuständige Aufsichtsbehörde (LDA Brandenburg statt LDI NRW), Datenkategorien und Empfänger an das Baugeschäft angepasst. **Änderungsvermerk v1.2:** Aufgewertete Ausgabe (klickbares Inhaltsverzeichnis mit Anker-Links, verbesserte Tabellen-Darstellung, **Fußnoten** zu Rechtsquellen) sowie zusätzliche browserfreundliche HTML-Ansicht mit Navigations-Seitenleiste. **Änderungsvermerk v1.1:** Durchgängige `Annahme:` / `Offene Frage:`-Kennzeichnung, `{{PLATZHALTER}}`-Mechanismus in allen Vorlagen, neuer Abschnitt zur `.env`-Ableitungslogik, 4-spaltige Offene-Fragen-Tabelle, ergänzte kostengünstige/Open-Source-Optionen. **Vertraulichkeit:** Streng vertraulich — nur zur internen Verwendung

---

> **Rechtlicher Hinweis / Haftungsausschluss:** Dieser Bericht ist eine praxisorientierte fachliche Aufbereitung des Datenschutz-Status und **keine Rechtsberatung**. Er ersetzt weder die Prüfung durch einen Datenschutzbeauftragten noch durch einen Fachanwalt für IT-/Datenschutzrecht. Alle enthaltenen Muster (Datenschutzerklärung, AVV-Klauseln, Einwilligungen, Meldevorlagen, Antwortschreiben) sind Textbausteine, die vor produktivem Einsatz rechtlich zu prüfen und an die tatsächlichen Verhältnisse anzupassen sind. Bei rechtlichen/vertraglichen Fragen gilt durchgängig: **„Bitte Rechtsabteilung / Fachanwalt für IT-Recht prüfen."**
>
> **Hinweis zur Faktenlage & zu `.env`-Werten:** Dieser Bericht sollte laut Auftrag aus Umgebungsvariablen (`.env`: z. B. `HOSTING_PROVIDER`, `CMS`, `THIRD_PARTY_SERVICES`, `INTEGRATIONS`) gespeist werden. **In der Arbeitsumgebung war jedoch keine `.env`, keine `config.yaml` und keine entsprechende Umgebungsvariable vorhanden** (nur `config.example.yaml`). Die im Auftrag beispielhaft genannten Werte („Hetzner", „WordPress") sind daher **Beispiele, keine bestätigten Daten**. Alle aus diesen Variablen ableitbaren Angaben sind deshalb als **`Annahme:`** gekennzeichnet und über `{{PLATZHALTER}}` sowie den Fragenkatalog (Kap. 16/17) als offene Punkte geführt. Verifizierte Fakten zum Unternehmensprofil stammen von der Website fraesdienst-feind.de und dem Notion Marketing-Scan (09/2026); technische Fakten aus der internen SEO-/Lead-Reporting-Codebasis (`config.example.yaml`, `docs/SPEC.md`, `docs/SETUP.md`, `data/crm/leads.example.csv`).
>
> **Seit v1.5** liegt im Repository-Wurzelverzeichnis eine **`.env`-Vorlage (`.env.example`)** bereit, in der alle hier genannten Variablen aufgeführt sind. Sobald David/IT diese Vorlage nach `.env` kopiert und mit echten Werten füllt (`cp .env.example .env`), lassen sich die Annahmen in **Fakten** überführen und der Bericht kann darauf gestützt aktualisiert werden (Anhang Q).
>
> **Platzhalter-Mechanismus:** Alle Vorlagen und mehrere Textstellen enthalten Platzhalter in doppelten geschweiften Klammern, z. B. `{{COMPANY_NAME}}`, `{{ADRESSE}}`, `{{GESCHAEFTSFUEHRER}}`, `{{HOSTING_PROVIDER}}`, `{{CMS}}`, `{{DPO_CONTACT}}`, `{{USt-IdNr}}`. Vor produktivem Einsatz per Suchen-&-Ersetzen mit echten Werten füllen. Eine vollständige Platzhalter-Liste steht in **Anhang R**.

Inhaltsverzeichnis

0. `.env`-Ableitungslogik (Datenquelle des Berichts)
1. Executive Summary
2. Unternehmens- und Tätigkeitsbeschreibung
3. Rechtsgrundlagen & Compliance-Check
4. Dateninventar & Verzeichnis der Verarbeitungstätigkeiten (VVT)
5. Datenflussanalyse (Data Flow Mapping)
6. Technische und organisatorische Maßnahmen (TOM)
7. Drittanbieter, Auftragsverarbeitung & Verträge
8. Datenschutz-Folgenabschätzung (DPIA)
9. Datensicherheit & Vorfallmanagement
10. Betroffenenrechte & Prozesse
11. Einwilligungen, Informationspflichten & Datenschutzerklärung
12. Spezifische Prüfung Web/Online-Tools
13. Mitarbeiter, Schulung & Rollen
14. Risikoanalyse & Priorisierung
15. Audit- & Monitoringplan
16. Antworten auf den Fragen-Katalog
17. Offene Fragen (priorisiert, 4-spaltig)
18. Anhänge & Vorlagen

---

0. `.env`-Ableitungslogik (Datenquelle des Berichts)

Der Bericht ist so konstruiert, dass er aus einer `.env`/Konfiguration automatisch mit realen Werten befüllt werden kann. Da aktuell **keine** solchen Werte gesetzt sind, dokumentiert dieser Abschnitt die **Ableitungsregeln** und den jeweils gesetzten Platzhalter/Annahmestatus.

> **`.env`-Vorlage (seit v1.5):** Die Datei `.env.example` im Repository-Wurzelverzeichnis enthält alle unten aufgeführten Variablen als leere, kommentierte Vorlage. Zum Befüllen: `cp .env.example .env` und echte Werte eintragen. Die echte `.env` ist per `.gitignore` ausgeschlossen und wird **nie** committet (nur die Vorlage `.env.example` ist versioniert).

`.env`-Variable	Ableitung / datenschutzrechtliche Konsequenz	Aktueller Status
`COMPANY_NAME`	Verantwortlicher i. S. v. Art. 4 Nr. 7; Kopf aller Vorlagen	**Annahme:** „Fräsdienst-Service E. Feind GmbH" (aus Codebasis-Markenbegriffen); Firmierung bestätigen → Platzhalter `{{COMPANY_NAME}}`
`HOSTING_PROVIDER`	Auftragsverarbeiter (Art. 28) → AVV nötig; Serverstandort → Drittstaatenprüfung (Art. 44 ff.)	**Offene Frage:** nicht gesetzt → `{{HOSTING_PROVIDER}}`
`CMS`	Bestimmt Tracking-/Cookie-/Plugin-Landschaft und DSE-Bausteine	**Offene Frage:** nicht gesetzt → `{{CMS}}`
`THIRD_PARTY_SERVICES`	Jeder Dienst ⇒ AVV-Pflicht prüfen + Drittstaatenbezug + DSE-Passus	**Teilweise verifiziert:** Google GSC/GA4, Google Cloud, GitHub, SMTP (aus Codebasis); weitere unbekannt
`INTEGRATIONS` (APIs/Zapier/Webhooks)	Datenübermittlung an Dritte ⇒ dokumentieren, Zweck/Empfänger/Rechtsgrundlage	**Teilweise verifiziert:** Google-APIs, GitHub Actions; **Annahme:** kein Zapier/IFTTT
`NEWSLETTER_TOOL`	Einwilligung (Art. 6 I a), Double-Opt-in, AVV, Consent-Log	**Offene Frage:** nicht gesetzt → `{{NEWSLETTER_TOOL}}`
`PAYMENT_PROVIDER`	AVV/eigenständig Verantwortlicher, Zahlungsdaten	**Offene Frage:** nicht gesetzt → `{{PAYMENT_PROVIDER}}`
`BACKUP_SOLUTION` / `BACKUP_RETENTION`	Speicherbegrenzung (Art. 5 I e), Löschkonzept, Verschlüsselung	**Offene Frage:** nicht gesetzt

Beispiel-Ableitung (zur Veranschaulichung, NICHT als Fakt): *Annahme:* Wäre `HOSTING_PROVIDER=Hetzner` gesetzt, folgte: Verarbeitung in Deutschland (kein Drittstaat), AVV nach Art. 28 verfügbar (Hetzner stellt AVV bereit), TOM-Nachweis über ISO 27001 des Anbieters. *Da nicht gesetzt, bleibt dies eine Annahme mit Platzhalter `{{HOSTING_PROVIDER}}`.*

---

1. Executive Summary

{{COMPANY_NAME}} verarbeitet als B2B-Dienstleister für Kaltfräsarbeiten im Straßen- und Tiefbau (Asphalt-/Betonfräsen, Grinding & Grooving) überwiegend Kunden-, Auftrags-, Lieferanten- und Beschäftigtendaten sowie Website-Besucherdaten. Das Datenschutzniveau ist in Teilbereichen solide (DSGVO-bewusste Trennung von Rohdaten und Code, kein Datenverkauf, überschaubare Verarbeitungslandschaft), es fehlen jedoch **zentrale Pflichtdokumente und Nachweise**.

Größte Risiken (Kurzfassung):

1. **Website-Tracking ohne rechtssicheres Consent (hoch).** Google Analytics 4 ist nachweislich im Einsatz. Ohne vorheriges Opt-in per Consent-Banner (§ 25 TDDDG) und ohne aktuelle Datenschutzerklärung drohen Abmahnungen/Bußgelder.
2. **Fehlendes VVT (Art. 30) und fehlende AV-Verträge (Art. 28) (hoch).**
3. **US-Datentransfer (mittel–hoch).** Google übermittelt in die USA; Rechtsgrundlage EU-US Data Privacy Framework dokumentierbar, aber zu belegen.
4. **Fehlendes Löschkonzept & TOM-Dokumentation (mittel).**
5. **Fehlender Prozess für Betroffenenrechte und Datenpannen (mittel).**

Top-Sofortmaßnahmen (0–3 Monate): Consent-Banner mit Opt-in vor GA4; Datenschutzerklärung und Impressum aktualisieren; VVT erstellen; AV-Verträge einholen/prüfen; Löschkonzept und Datenpannen-Meldeprozess; klären, ob ein DSB zu benennen ist.

Der Handlungsbedarf liegt fast vollständig in **Dokumentation, Consent-Konfiguration und Prozessen** — nicht in teurer Technik. Mit überschaubarem Aufwand (inkl. Open-Source-Optionen) ist innerhalb von 12 Monaten ein belastbares Konformitätsniveau erreichbar. Umsetzung siehe **To-Do-Plan (Anhang K)**, **Risiko-Dashboard (Anhang O)** und **12-Monats-Roadmap (Anhang N)**.

(Executive Summary: ~230 Wörter)

---

2. Unternehmens- und Tätigkeitsbeschreibung

2.1 Kurzprofil (Fakten + Annahmen)

Verifiziert (Website fraesdienst-feind.de, Notion Marketing-Scan 09/2026): Auftritt als „E. Feind GmbH" / „Fräsdienst Feind", Domain `fraesdienst-feind.de`. Geschäftsfelder: **Kaltfräsen von Asphalt und Beton** (Straßen, Autobahnen, Gewerbe-/Industrieflächen, Flughäfen), **Grinding & Grooving**, Pflasterschleifen, Sonderlösungen und Rundum-Service (Fräsgutaufnahme, Kehrsauger). Über 30 Wirtgen-Fräsmaschinen. **Hauptsitz Lübben (Brandenburg), Niederlassung Wittenburg (Mecklenburg-Vorpommern)**, Einsatz deutschlandweit. Auftraggeber: Straßen-/Tiefbauunternehmen, Kommunen, Flughäfen, Industrie. Lead-Quellen: Website-Kontaktformular, Telefon, E-Mail, Ausschreibungen, Empfehlung, Messe.

- **Annahme:** KMU mit **< 20 Personen**, die ständig automatisiert personenbezogene Daten verarbeiten → keine gesetzliche DSB-Pflicht nach § 38 BDSG (bestätigen, siehe Kap. 3).

- **Annahme:** Hauptsitz und Verarbeitung in **Lübben (Brandenburg)** → Aufsichtsbehörde **LDA Brandenburg** (Landesbeauftragte für den Datenschutz und für das Recht auf Akteneinsicht Brandenburg); für die Niederlassung Wittenburg ggf. **LfDI Mecklenburg-Vorpommern** (Zuständigkeit bei Meldung verifizieren).
- **Annahme:** Keine **besonderen Kategorien** (Art. 9) zu Kunden; im Beschäftigtenkontext nur begrenzt Gesundheitsdaten (AU-Bescheinigungen).
- **Annahme:** Kein **Profiling / keine automatisierte Einzelentscheidung** (Art. 22).

2.2 Rolle der berichtenden Person

David Halko ist **Marketing & Eventmanager**. Datenschutzrelevante Berührungspunkte: Website und Marketing-Tools (Analytics, ggf. Newsletter, Social Media), Interessenten-/Lead-Daten (Kontaktformular, Messe), Auswahl externer Dienstleister (Web-Agentur, Tools), Marketing-Content mit möglichem Personenbezug (Referenzen, Event-Fotos).

- **Annahme:** David ist **nicht** DSB; die Marketing-Rolle ist wegen Interessenkonflikt für die DSB-Funktion ungeeignet. Empfohlene Rolle: **Prozessverantwortlicher „Marketing & Website"** (siehe Rollenmatrix, Kap. 13).

---

3. Rechtsgrundlagen & Compliance-Check

3.1 Relevante Rechtsgrundlagen

Norm	Bedeutung für {{COMPANY_NAME}}
Art. 6 Abs. 1 DSGVO	lit. b (Vertrag/Anbahnung), lit. c (Rechnungen/Steuer), lit. f (Direktwerbung Bestandskunden, IT-Sicherheit), lit. a (Analytics, Newsletter).
Art. 7 DSGVO	Bedingungen für Einwilligung (freiwillig, informiert, widerrufbar, nachweisbar).
Art. 9 DSGVO	Besondere Kategorien — v. a. Beschäftigten-Gesundheitsdaten (AU).
Art. 5, 13, 14 DSGVO	Grundsätze; Informationspflichten.
Art. 15–22 DSGVO	Betroffenenrechte.
Art. 28 / 30 / 32 DSGVO	AV-Vertrag, VVT, Sicherheit der Verarbeitung (TOM).
Art. 33 / 34 / 35 DSGVO	Datenpannen-Meldung (72 h), Benachrichtigung, DPIA.
§ 26 BDSG	Beschäftigtendatenschutz.
§ 38 BDSG	DSB-Benennungspflicht (ab 20 Personen mit automatisierter Verarbeitung oder bei DPIA-Pflicht).
§ 25 TDDDG[3] (vormals TTDSG)	Einwilligung für Zugriff auf Endgeräte-Informationen (Cookies/Tracking) — Opt-in.
ePrivacy-Richtlinie	Grundlage der Cookie-/Tracking-Regeln (national: TDDDG).
§ 147 AO, § 257 HGB	Aufbewahrungspflichten (Löschkonzept).

3.2 Compliance-Check (Status)

Legende: 🟢 erfüllt · 🟡 teilweise · 🔴 nicht erfüllt / unbekannt

#	Pflicht / Dokument	Rechtsgrundlage	Status	Bemerkung
1	Verzeichnis der Verarbeitungstätigkeiten (VVT)	Art. 30	🔴	Vorlage in Anhang A.
2	Datenschutzerklärung Website (aktuell)	Art. 13	🟡	**Annahme:** vorhanden, Aktualität unklar — Muster Anhang E.
3	Impressum	§ 5 DDG	🟡	**Annahme:** vorhanden; Vollständigkeit prüfen.
4	Cookie-/Consent-Banner mit Opt-in vor GA4	§ 25 TDDDG, Art. 6/7	🔴	Kritisch — GA4 aktiv.
5	AV-Verträge mit Auftragsverarbeitern	Art. 28	🔴	Google, Hoster, Steuerberater, IT-Support, ggf. Lohn.
6	TOM-Dokumentation	Art. 32	🔴	Checkliste Anhang J.
7	Löschkonzept / Aufbewahrungsfristen	Art. 5 I e	🔴	Vorlage Kap. 4.
8	Prozess Betroffenenrechte	Art. 15–22	🔴	Kap. 10.
9	Datenpannen-Meldeprozess (72 h)	Art. 33/34	🔴	Kap. 9.
10	Prüfung DSB-Benennungspflicht	§ 38 BDSG	🟡	Personenzahl klären.
11	Verpflichtung auf Vertraulichkeit (Beschäftigte)	Art. 29, § 53 BDSG	🔴	Vorlage empfohlen.
12	DPIA (falls erforderlich)	Art. 35	🟡	Nach aktueller Einschätzung nicht zwingend (Kap. 8).
13	Mitarbeiterschulung Datenschutz	Art. 39 (Best Practice)	🔴	Kein Nachweis — Kap. 13.
14	US-Transfer-Nachweis (DPF/SCC)	Art. 44 ff.	🟡	Google DPF-zertifiziert; dokumentieren.

> **Kernaussage:** Die technische Verarbeitung ist überschaubar; der Handlungsbedarf liegt in **Dokumentation, Consent-Konfiguration und Prozessen**.

---

4. Dateninventar & Verzeichnis der Verarbeitungstätigkeiten (VVT)

4.1 Kategorien personenbezogener Daten

Betroffenengruppe	Typische Datenkategorien
Kunden / Ansprechpartner	Name, Firma, Funktion, Anschrift, E-Mail, Telefon, Auftrags-, Rechnungs-/Zahlungsdaten, Ausschreibungsunterlagen, Leistungsverzeichnisse, Lagepläne, Baustellenfotos (i. d. R. kein Personenbezug, aber vertraulich).
Interessenten / Leads	Name, Firma, E-Mail, Telefon, Anfrageinhalt.
Lieferanten / Dienstleister	Ansprechpartner, Kontakt-, Vertrags-, Zahlungsdaten.
Beschäftigte	Stammdaten, Vertrag, Lohn-/SV-Daten, Bankverbindung, Arbeitszeit, **Gesundheitsdaten (AU)** — Art. 9.
Bewerber	Bewerbungsunterlagen, Lebenslauf, Zeugnisse, Kontaktdaten.
Website-Besucher	IP-Adresse, Geräte-/Browserdaten, Nutzungsdaten (Analytics), Cookie-IDs.

4.2 Verzeichnis der Verarbeitungstätigkeiten (ausgefüllte Beispiel-Einträge)

> Vollständige, kopierfähige CSV-Vorlage siehe **Anhang A**. Auszug:

Verarbeitung	Zweck	Rechtsgrundlage	Datenkategorien	Speicherort	Aufbewahrung	Zugriff	
Kundenverwaltung / Auftragsabwicklung	Angebot, Vertrag, Ausführung auf der Baustelle, Rechnung	Art. 6 I b, c	Stamm-, Auftrags-, Rechnungsdaten	ERP/Ablage, Buchhaltung, Cloud	Rechnungen 8–10 J. (§ 147 AO); sonst 3 J. (§ 195 BGB)	GF, Vertrieb, Buchhaltung, Bauleitung/Disposition	
Interessenten/Kontaktformular	Anfragebearbeitung	Art. 6 I b, f	Name, Firma, Kontakt, Anliegen	Website→E-Mail/CRM(CSV)	Löschung n. Erledigung, spät. 6–12 Mon.	Vertrieb, Marketing	
Website-Analyse (GA4)	Reichweiten-/Nutzungsanalyse	**Art. 6 I a (Einwilligung)**	IP, Geräte-/Nutzungsdaten, Cookie-IDs	Google (EU/USA)	GA4-Standard, konfigurierbar (2–14 Mon.)	Marketing	
Suchperformance (Search Console)	SEO-Analyse	Art. 6 I f	aggregierte Suchdaten (i. d. R. kein Personenbezug)	Google	Google-seitig	Marketing	
Beschäftigtenverwaltung/Lohn	Personalverwaltung, Lohn	Art. 6 I b, c; § 26 BDSG; Art. 9 II b	Stamm-, Lohn-, Gesundheitsdaten	Personalakte, Lohnsystem	6–10 J. lohnsteuer-/sozialrechtl.	GF, Personal, Lohnbüro	
Bewerbermanagement	Auswahlverfahren	Art. 6 I b; § 26 BDSG	Bewerbungsdaten	E-Mail/Ablage	Absage: Löschung nach **6 Monaten**	GF, Personal	
Newsletter/Marketing *(falls genutzt)*	Direktwerbung	**Art. 6 I a**	E-Mail, Name, ggf. Interessen	{{NEWSLETTER_TOOL}}	Bis Widerruf; Consent-Log dauerhaft	Marketing	
IT-Sicherheit/Server-Logs	Betriebssicherheit	Art. 6 I f	IP, Zeitstempel, Zugriffsdaten	{{HOSTING_PROVIDER}}	i. d. R. 7–30 Tage	IT/Hoster	

5. Datenflussanalyse (Data Flow Mapping)

5.1 Ein- und Ausgangspunkte

Eingang: Website-Kontaktformular · E-Mail · Telefon · Messe/persönlich · Papierdokumente (Leistungsverzeichnisse, Lieferscheine, Aufmaße) · Bewerbungen · Ausschreibungs-/Planunterlagen (Lagepläne — i. d. R. kein Personenbezug) · Maschinen-/Telematikdaten der Fräsmaschinen und Fahrzeuge (Offene Frage: Fahrer-/Standortbezug → ggf. Beschäftigtendaten, Betriebsvereinbarung prüfen).

Ausgang: Steuerberater/Lohnbüro · Finanzamt/SV-Träger (gesetzlich) · Subunternehmer/Entsorgung/Logistik · Zahlungsdienstleister/Bank · Google (Analytics/Search Console) · Hosting-Provider · IT-Support/Fernwartung · ggf. Newsletter-Tools · GitHub (nur Code/Konfiguration, **keine** produktiven CRM-Rohdaten — durch `.gitignore` ausgeschlossen).

5.2 Lebenszyklus-Tabelle (Erfassung → Löschung)

Datenfluss	1. Erfassung	2. Speicherung	3. Verarbeitung	4. Weitergabe	5. Löschung	Drittland?
Kundenauftrag	Formular/E-Mail/Tel.	ERP/Ablage/Cloud	Angebot→Ausführung→Rechnung	Steuerberater, Subunternehmer	Fristablauf (8–10 J.)	**Offene Frage:** Cloud-Standort
Website-Analyse	Browser (Cookie)	Google GA4	Aggregation, Reporting	Google	GA4-Retention	**Ja — USA (DPF)**
Lead/Interessent	Formular/Messe	E-Mail/CRM-CSV	Nachfassen, Angebot	intern	nach Erledigung	**Offene Frage:** Hoster-Standort
Beschäftigte/Lohn	Personalbogen	Personalakte/Lohnsystem	Abrechnung	Lohnbüro, FA, SV	Fristablauf	**Annahme:** EU

Datenfluss	1. Erfassung	2. Speicherung	3. Verarbeitung	4. Weitergabe	5. Löschung	Drittland?
Bewerbung	E-Mail	Ablage	Auswahl	intern	6 Mon. n. Absage	**Annahme:** EU
Server-Logs	HTTP-Request	{{HOSTING_PROVIDER}}	Fehler-/Sicherheitsanalyse	Hoster	7–30 Tage	**Offene Frage:** Standort

5.3 Grenzüberschreitende Übermittlungen (Drittstaaten)

- **Google (GA4, Search Console, Google Cloud):** Übermittlung in die **USA** möglich. Rechtsgrundlage: **EU-US Data Privacy Framework** (Angemessenheitsbeschluss vom 10.07.2023)[1]; Google LLC ist DPF-zertifiziert; SCC als Auffanglösung. → **Dokumentieren.**
- **GitHub (Microsoft):** USA möglich; enthält nur Code/Konfiguration, keine produktiven personenbezogenen Rohdaten.
- **Annahme:** Hosting/E-Mail/Newsletter in EU — **Offene Frage:** Standort/Drittstaatenbezug zu verifizieren.

---

6. Technische und organisatorische Maßnahmen (TOM)

Empfohlene TOM nach Art. 32 DSGVO, mit Priorität (H/M/N), Aufwand und ggf. kostengünstiger/ Open-Source-Option (neutral, keine Kaufempfehlung).

Bereich	Maßnahme	Prio	Aufwand	Kostengünstige/OSS-Option
Zugriffskontrolle	Rollen-/Berechtigungskonzept „need-to-know"; individuelle Logins	H	mittel	Bordmittel (AD/Google Workspace)
Authentifizierung	Passwort-Policy + **MFA** (E-Mail, Cloud, Google, GitHub, Buchhaltung)	H	gering–mittel	KeePassXC / Bitwarden; TOTP-Apps
Verschlüsselung (Transit)	TLS/HTTPS Website & E-Mail, HSTS	H	gering	Let's Encrypt
Verschlüsselung (at rest)	Geräteverschlüsselung; verschlüsselte Backups	H	gering	BitLocker/FileVault; VeraCrypt/Cryptomator
Backup	3-2-1-Strategie, Wiederherstellungstests, Aufbewahrung definiert	H	mittel	restic / BorgBackup
Patch-Management	Auto-Updates OS/CMS/Plugins/AV; Turnus dokumentieren	H	gering	Bordmittel
Endpoint-Security	Virenschutz/Firewall, Bildschirmsperre	M	gering	OS-Bordmittel (Defender)
Logging/Monitoring	Zugriffs-/Server-Logs, Aufbewahrung 7–30 Tage, zweckgebunden	M	gering	Hoster-Bordmittel
Physische Sicherheit	Abschließbare Serverräume/Aktenschränke, Aktenvernichtung (DIN 66399)	M	gering–mittel	—
Mobile Geräte	Trennung privat/dienstlich, Fernlöschung	M	mittel	Google/MS-Bordmittel
Fernwartung	Nur nach Freigabe, protokolliert, verschlüsselt; AVV	M	gering	RustDesk (self-hosted)
Löschung/Entsorgung	Löschroutinen; sichere Datenträgervernichtung	M	mittel	—
Belastbarkeit	Notfallplan (IT-Ausfall/Ransomware), Wiederanlauf	M	mittel	—
Website-Analyse	GA4-Alternative mit Datenhoheit prüfen	N	mittel	**Matomo** (self-hosted, oft ohne Consent-Pflicht konfigurierbar)

---

7. Drittanbieter, Auftragsverarbeitung & Verträge

7.1 Auftragsverarbeiter (Art. 28) — teils verifiziert, teils Annahme

Dienstleister	Zweck	AVV erforderlich?	Drittland	Status
Google (LLC/Ireland)	GA4, Search Console, Google Cloud	Ja	USA (DPF)	AVV via Google-Bedingungen aktivieren/prüfen (verifiziert im Einsatz)
{{HOSTING_PROVIDER}}	Website, Postfächer, Logs	Ja	**Offene Frage**	AVV einholen
Steuerberater	Buchhaltung, Jahresabschluss	i. d. R. **eigenständig Verantwortlicher**	EU	schriftlich klären
{{PAYROLL_PROVIDER}} (Lohn)	Gehaltsabrechnung	AVV oder Berufsträger	EU	klären
{{IT_SUPPORT}} / Fernwartung	Wartung, Support	Ja	**Offene Frage**	AVV einholen
{{NEWSLETTER_TOOL}} *(falls genutzt)*	E-Mail-Marketing	Ja	**Offene Frage**	AVV einholen
Subunternehmer/Entsorger/Logistik	Baustellenlogistik, Fräsgut-Entsorgung	meist eigenständig Verantwortlicher	EU	klären
GitHub (Microsoft)	Code-/Config-Hosting	Ja (soweit personenbezogen)	USA (DPF)	prüfen; keine Rohdaten (verifiziert)
Kartenkachel-Anbieter (Feind Cockpit, Straßenkarte)	Auslieferung von Kartenkacheln; dabei IP-Adresse, Zeitpunkt, Browserkennung	Bei OpenStreetMap: eigenständig Verantwortlicher, kein AVV angeboten. Bei einem kommerziellen Anbieter (z. B. MapTiler): AVV/DPA prüfen	**Annahme:** OSMF = Vereinigtes Königreich (Angemessenheitsbeschluss), Auslieferung über CDN; EU-Anbieter vorzuziehen	Nur nach Einwilligung je Person (Abschnitt 12.1); Anbieter vor Produktivbetrieb festlegen

7.2 AVV-Prüfliste

1. Vertrag schriftlich/elektronisch, aktuell, DSGVO-konform (Art. 28 Abs. 3).

2. Gegenstand, Dauer, Art, Zweck, Datenkategorien, Betroffene benannt.
3. Weisungsbindung, Vertraulichkeit, TOM (Art. 32).
4. Unterauftragsverarbeiter mit Genehmigungsvorbehalt/Liste.
5. Unterstützung bei Betroffenenrechten und Datenpannen.
6. Löschung/Rückgabe nach Vertragsende.
7. **Kontroll-/Audit-Rechte** und Nachweispflichten.
8. Drittlandtransfer-Grundlage (DPF/SCC) dokumentiert.

> Muster-AVV-Klauseln siehe **Anhang C**.

---

8. Datenschutz-Folgenabschätzung (DPIA)

8.1 Wann erforderlich? (Art. 35)

Pflicht bei „voraussichtlich hohem Risiko": systematische umfangreiche Überwachung, umfangreiche Verarbeitung besonderer Kategorien, systematisches Scoring/Profiling — sowie bei Verarbeitungen auf der Muss-Liste der Aufsichtsbehörden.

- **Annahme/Einschätzung:** Für {{COMPANY_NAME}} ist **keine DPIA zwingend** — kein großflächiges Tracking/Scoring, keine umfangreiche Verarbeitung besonderer Kategorien. GA4-Website-Analyse = **Standardrisiko**, sofern Consent und IP-Kürzung greifen. → **Kurz-Schwellwertprüfung dokumentieren** (Nachweis, dass geprüft und verneint wurde).

8.2 Vorgehen

1. Beschreibung & Zwecke → 2. Notwendigkeit/Verhältnismäßigkeit → 3. Risikoidentifikation →
2. Bewertung (Eintritt × Schwere) → 5. Abhilfemaßnahmen → 6. Restrisiko & Freigabe →
3. Monitoring/Review.

> Vollständige **DPIA-Vorlage mit Beispielen** (Kundenverwaltung, Ausschreibungs-/Planunterlagen, Fernwartung) siehe **Anhang B**.

---

9. Datensicherheit & Vorfallmanagement

1. **Erkennung & interne Meldung:** sofort an GF/IT-Verantwortlichen (Meldeweg dokumentieren).
2. **Sofortmaßnahmen & forensische Sicherung:** System isolieren, Logs/Beweise sichern, Umfang eingrenzen.
3. **Bewertung (Risiko für Betroffene):** Art, Umfang, Sensibilität, Anzahl, Folgen.
4. **Meldung an Aufsichtsbehörde (Art. 33):** bei Risiko **innerhalb 72 Stunden** (LDA Brandenburg); Verzögerung begründen.
5. **Benachrichtigung Betroffener (Art. 34):** bei **hohem** Risiko unverzüglich, klare Sprache.
6. **Dokumentation:** jeder Vorfall im **Datenpannen-Register** (Nachweispflicht Art. 33 Abs. 5).
7. **Nachbereitung:** Ursachenanalyse, TOM anpassen, ggf. Schulung.

> **Muster-Meldung Behörde** und **Betroffenen-Benachrichtigung** siehe **Anhang F**; **Incident-Report-Formular** siehe **Anhang G**.

---

10. Betroffenenrechte & Prozesse

Recht	Norm	Frist
Auskunft	Art. 15	1 Monat (verlängerbar um 2)
Berichtigung	Art. 16	unverzüglich, i. d. R. 1 Monat
Löschung	Art. 17	1 Monat (Aufbewahrungspflichten beachten)
Einschränkung	Art. 18	1 Monat
Datenübertragbarkeit	Art. 20	1 Monat
Widerspruch (u. a. Direktwerbung)	Art. 21	unverzüglich

Prozess: Eingang zentral erfassen (Datum!) → **Identität prüfen** (verhältnismäßig) → Betroffene(n)/Daten ermitteln → Antwort erstellen (ggf. mit DSB) → fristgerecht **kostenfrei** antworten → dokumentieren.

> Muster-Antwortschreiben (Auskunft, Löschung) siehe **Anhang H**.

---

11. Einwilligungen, Informationspflichten & Datenschutzerklärung

- **Datenschutzerklärung (Art. 13):** vollständig, aktuell, auffindbar — Muster **Anhang E**.
- **Cookie-/Consent-Banner: Opt-in vor** dem Laden nicht notwendiger Technologien (GA4!), granular, Ablehnen so einfach wie Akzeptieren, Widerruf jederzeit — Texte **Anhang D**. *Kostengünstige/OSS-Option:* **Klaro!** oder Cookie-consent (Orestbida) als Consent-Tool.
- **Newsletter/Marketing: Double-Opt-in**, klarer Zweck, Widerrufshinweis in jeder Mail.
- **Consent-Logs:** Nachweis protokollieren (Zeitpunkt, eingewilligte Zwecke, Textversion, technischer Nachweis).

---

12. Spezifische Prüfung Web/Online-Tools

> **Offene Frage (hoch):** Ein Live-Abruf der Website war in der Arbeitsumgebung netzwerkseitig gesperrt. Folgende Punkte sind **verifiziert (V)** oder `Annahme:` und per Live-Audit zu bestätigen (F-01).

(V) Verifiziert: GA4 im Einsatz (Key-Event `anfrage_gesendet`); Domain als GSC-Property registriert; Website-Kontaktformular vorhanden.

Prüf-Checkliste (Soll-Zustand):

1. **Tracking (GA4):** lädt erst **nach Opt-in**? IP-Anonymisierung/Retention konfiguriert? Google-Signals ohne Einwilligung deaktiviert? — **Annahme:** aktuell ohne Opt-in.
2. **Google Tag Manager:** vorhanden? consent-gesteuert? — **Offene Frage.**
3. **Google Fonts: lokal gehostet** (nicht dynamisch nachladen — vgl. LG München 2022[2])? — **Annahme:** häufiges KMU-Risiko, oft extern.
4. **Google Maps / reCAPTCHA / YouTube:** nur nach Consent (2-Klick)? — **Offene Frage.**
5. **Social-Media-Plugins:** kein Einbetten ohne Consent? — **Offene Frage.**
6. **CDN / externe Skripte:** Herkunft/Drittlandbezug dokumentiert? — **Offene Frage.**
7. **SSL/TLS:** HTTPS erzwungen, gültiges Zertifikat, **HSTS**? — **Annahme:** HTTPS aktiv.
8. **CSP:** gesetzt? — **Offene Frage.**
9. **Cookies/LocalStorage:** vollständiges Inventar (Name, Zweck, Laufzeit, Anbieter)? — **Offene Frage.**
10. **Consent-Banner-Tool:** vorhanden, Opt-in, granular, Widerruf, Consent-Log? — **Annahme:** fehlt/unzureichend.

Empfehlungen: Consent-Management einführen und GA4 daran koppeln (oder auf Matomo mit Datenhoheit umstellen); Google Fonts lokal einbinden; Cookies inventarisieren; DSE an tatsächlich geladene Dienste anpassen; TLS/HSTS erzwingen.

12.1 Internes Feind Cockpit – Kartenansicht der Ausschreibungen (Stand v3.1, 01.10.2026)

Betrifft das Artefakt „Feind Cockpit“ (Quelle: `cockpit-a1/Feind-Cockpit-A1.html`, bis 19.10.2026 `messe/rotterdam-2027/feind-cockpit-v3.html`, Doku: `messe/rotterdam-2027/KARTE.md`). Nutzerkreis: Beschäftigte, keine Website-Besucher.

Datenfluss	Wann	Empfänger	Daten	Rechtsgrundlage (Vorschlag)
Umrisskarte, Bundesländer, Pins	immer	keiner (eingebettet)	–	–
Schrift Exo	immer	keiner (lokal eingebettet, seit v3.1)	–	–
Straßenkarte (Kartenkacheln)	erst nach Klick auf „Einwilligen und laden“	konfigurierter Kachelanbieter; Standard OpenStreetMap (`tile.openstreetmap.org`)	IP-Adresse, Zeitpunkt, Browserkennung, abgerufener Kartenausschnitt	Einwilligung, Art. 6 Abs. 1 lit. a DSGVO i. V. m. § 25 Abs. 1 TDDDG (konservativ; berechtigtes Interesse wäre bei EU-Anbieter denkbar)
Einwilligungsstand	bei Erteilung	nur im Browser der Person (`localStorage`, Schlüssel `feind-cockpit:osm-consent`: Host, Zeitpunkt, an/aus)	keine Übermittlung	–

Umgesetzte Maßnahmen: Ohne Einwilligung keine externen Requests (automatisiert geprüft, `messe/rotterdam-2027/e2e/karte.e2e.mjs`); Einwilligung gilt je Anbieter-Host und wird bei Anbieterwechsel neu eingeholt; Widerruf mit einem Klick („Einwilligung widerrufen“); Namensnennung „© OpenStreetMap-Mitwirkende“ (ODbL) immer sichtbar; Google Fonts entfernt.

Offen: OpenStreetMap-Kacheln sind laut Tile Usage Policy nur für geringe Last gedacht und ohne Verfügbarkeitszusage. Für den Dauerbetrieb einen Anbieter mit EU-Verarbeitung festlegen (Admin › Funktionen und Quellen), AVV prüfen und hier eintragen. **Bitte Rechtsabteilung prüfen**, ob Einwilligung oder berechtigtes Interesse gewählt wird und ob eine Information nach Art. 13 DSGVO im Beschäftigtenkontext ergänzt werden muss.

Textbaustein Datenschutzhinweis (Beschäftigte, Feind Cockpit):

> Kartenansicht: Das Feind Cockpit zeigt standardmäßig eine Umrisskarte ohne Verbindung zu Dritten. Wenn Sie die Straßenkarte laden und einwilligen, ruft Ihr Browser Kartenkacheln von {{KACHELANBIETER}} ({{KACHEL_HOST}}) ab. Dabei werden Ihre IP-Adresse, Datum und Uhrzeit sowie Angaben zu Ihrem Browser an diesen Anbieter übertragen. Rechtsgrundlage ist Ihre Einwilligung (Art. 6 Abs. 1 lit. a DSGVO, § 25 Abs. 1 TDDDG). Sie können sie jederzeit über „Einwilligung widerrufen“ in der Karte zurücknehmen; die Rechtmäßigkeit der bis dahin erfolgten Abrufe bleibt unberührt. Datenschutzhinweise des Anbieters: {{KACHEL_DATENSCHUTZ_URL}}.

---

13. Mitarbeiter, Schulung & Rollen

Schulung: Inhalte (DSGVO-Grundlagen, E-Mail-/Passwortverhalten, Phishing, Umgang mit Daten, Datenpannen-Meldung, Clean-Desk); Frequenz (Eintritt + **jährlich**); Nachweis (Teilnahmeliste/Signatur, Datum, Inhalt).

Rollenmatrix:

Rolle	Zuständigkeit	Vorschlag
Verantwortlicher	Gesamtverantwortung DSGVO	Geschäftsführung
DSB (falls nötig/gewünscht)	Beratung, Überwachung, Behördenkontakt	**Annahme:** extern empfohlen (Unabhängigkeit)
IT-Admin/-Verantwortlicher	TOM, Backup, Zugriffe, Patches	intern/IT-Dienstleister
Prozessverantw. Marketing/Website	Website, Analytics, Consent, Newsletter	**David Halko**
Prozessverantw. Personal	Beschäftigten-/Bewerberdaten	Personal/GF
Prozessverantw. Buchhaltung	Rechnungs-/Zahlungsdaten	Buchhaltung

---

14. Risikoanalyse & Priorisierung

Bewertung: Eintrittswahrscheinlichkeit (1–3) × Auswirkung (1–3) = Score (1–9).

#	Risiko	W	A	Score	Prio
R1	GA4/Tracking ohne rechtssicheres Consent	3	3	**9**	Hoch
R2	Fehlende AV-Verträge (Art. 28)	3	2	**6**	Hoch
R3	Fehlendes VVT (Art. 30)	3	2	**6**	Hoch
R4	Veraltete/unvollständige Datenschutzerklärung	3	2	**6**	Hoch
R5	US-Transfer nicht dokumentiert	2	2	**4**	Mittel
R6	Kein Löschkonzept	2	2	**4**	Mittel
R7	Kein Datenpannen-Prozess (72 h)	2	3	**6**	Hoch
R8	Fehlende TOM-Dokumentation	2	2	**4**	Mittel
R9	Google Fonts extern eingebunden	2	1	**2**	Niedrig
R10	Keine Mitarbeiterschulung	2	2	**4**	Mittel
R11	Kein MFA auf kritischen Konten	2	3	**6**	Hoch
R12	Bewerber-/Beschäftigtendaten ohne Löschfristen	2	2	**4**	Mittel

Zeitliche Zuordnung: Kurzfristig (0–3 Mon.): R1, R4, R7, R11, R2/R3 (Start) · Mittelfristig (3–12 Mon.): R2/R3 (Abschluss), R5, R6, R8, R10, R12 · Langfristig (>12 Mon.): R9, kontinuierliche Verbesserung, Audits.

---

15. Audit- & Monitoringplan

- **Interne Kurz-Audits:** halbjährlich (Checklisten Anhang J/L).
- **Jährlicher Review:** VVT, AVV, Löschungen, Schulungen, Vorfälle.
- **KPIs:** % abgeschlossene AVV; offene Betroffenenanfragen/Fristtreue; Zeit bis Datenpannen- Meldung; Schulungsquote; Anzahl offener Hoch-Risiken.
- **Reporting an GF:** halbjährlich (1-Seiter mit Ampelstatus).

---

16. Antworten auf den Fragen-Katalog

Meta-Fragen: Thema: DSGVO-Status/Maßnahmenplan fraesdienst-feind.de; Blickwinkel: interne Bestandsaufnahme + Handlungsplan; Zielgruppe: GF/DSB/IT/Behörde; Umfang: ausführlich; Format: gegliederter Bericht + Vorlagen; Ton: sachlich, praxisnah; Quellen: interne Codebasis + geltendes Recht (DSGVO/BDSG/TDDDG) + Branchenpraxis.

Fach-Fragen (V = verifiziert, `Annahme:` = Annahme):

Frage	Antwort
Interne Systeme/Tools	**V:** Google Search Console, GA4, Google Cloud (Service-Account), GitHub/Actions, SMTP (optional), Website-Kontaktformular, CRM als CSV/XLSX. **Annahme:** Buchhaltung/ERP/Cloud-Speicher/Backup — zu benennen (F-02).
Externe Dienstleister mit Datenzugriff	**Annahme:** Hoster, Steuerberater, ggf. Lohnbüro, IT-Support, Google, ggf. Newsletter (F-03).
Unterschriebene AVVs vorhanden?	**Annahme:** unbekannt, vermutlich unvollständig (F-05).
Drittstaatentransfer?	**V/Annahme:** ja via Google (USA, **DPF**); weitere prüfen (F-04).
Datenkategorien	siehe Kap. 4.1.

Frage	Antwort
Besondere Kategorien (Art. 9)?	**Annahme:** nur Beschäftigten-Gesundheitsdaten (AU).
Aufbewahrung/Löschkonzept?	**Annahme:** nicht formalisiert (F-07).
Backups?	**Annahme:** vorhanden, Fristen unklar (F-08).
Zugriffskontrolle/MFA?	**Annahme:** MFA nicht flächendeckend (R11, F-09).
Patch-Management?	**Annahme:** unklar (F-10).
Datenpannen-Protokoll/-Vorfall?	**Annahme:** kein Protokoll; kein gemeldeter Vorfall (F-11).
Einwilligungen dokumentiert?	**Annahme:** Consent-Log für GA4/Newsletter fraglich (R1).
Betroffenenrechte-Prozess?	**Annahme:** nicht dokumentiert (Kap. 10).
Schulungen?	**Annahme:** keine dokumentiert (R10).
Logs & Aufbewahrung?	**Annahme:** Server-Logs beim Hoster, Dauer unklar (F-06).
Verschlüsselung?	**Annahme:** HTTPS aktiv; Geräte-/Backup-Verschlüsselung prüfen.
Physische Sicherheit?	**Annahme:** zu prüfen.
Tracking/Social-Plugins?	**V:** GA4; weitere **Annahme** (F-01).
Schnittstellen/APIs/Zapier/Webhooks?	**V:** Google-APIs (GSC/GA4), GitHub Actions, SMTP. **Annahme:** kein Zapier/IFTTT.
Automatisierte Entscheidung/Profiling?	**Annahme:** nein.
Löschkonzept bei Kundenende?	**Annahme:** nicht vorhanden (F-07).
Fehlende Nachweise?	VVT, AVV, TOM, Löschkonzept, Consent-Log, Schulungsnachweise.
Prioritäten kurz/mittel/lang?	siehe Kap. 14 & Roadmap (Anhang N).

17. Offene Fragen (priorisiert, 4-spaltig)

Frage	Warum offen	Benötigte Info	Priorität
F-01 Welche Cookies/Tracker/Fonts/Consent-Tool sind real aktiv?	Live-Website-Audit in Umgebung gesperrt	Zugriff auf Website/CMS oder externer Cookie-Scan	Hoch
F-05 Welche AV-Verträge existieren, aktuell/vollständig?	Keine Vertragsdaten vorhanden	Vertragsübersicht/AVV-Kopien	Hoch
F-09 MFA auf E-Mail/Cloud/Google/GitHub/Buchhaltung aktiv?	Keine IT-Konfig einsehbar	Bestätigung IT / Screenshots	Hoch
F-11 Datenpannen-Meldeprozess/-Register vorhanden?	Kein Prozessdokument bekannt	Auskunft GF/IT	Hoch
F-02 Buchhaltungs-/ERP-/Cloud-Speicher-/Backup-Lösungen (Anbieter/Standort)?	Keine `.env` /Config vorhanden	`THIRD_PARTY_SERVICES` , Anbieterliste	Mittel
F-03 Vollständige Liste externer Dienstleister mit Datenzugriff	Nur teilweise aus Codebasis ableitbar	Dienstleisterverzeichnis	Mittel
F-04 Serverstandorte Hosting/E-Mail/Newsletter (Drittstaaten?)	`HOSTING_PROVIDER` nicht gesetzt	Anbieter + Rechenzentrumsstandort	Mittel
F-07 Löschkonzept mit Fristen vorhanden?	Kein Dokument bekannt	Aufbewahrungs-/Löschregeln	Mittel
F-12 Personenzahl mit automatisierter Verarbeitung → DSB-Pflicht?	Headcount unbekannt	Mitarbeiterzahl (§ 38 BDSG)	Mittel
F-06 Log-Aufbewahrungsdauer beim Hoster	Keine Hoster-Config	Hoster-Logpolicy	Niedrig
F-08 Backup-Fristen und Wiederherstellungstests	Keine Backup-Config	`BACKUP_RETENTION` , Testnachweise	Niedrig
F-10 Patch-/Update-Turnus dokumentiert?	Keine IT-Dokumentation	Update-Prozessbeschreibung	Niedrig
F-13 CMS/Website-Technologie?	`CMS` nicht gesetzt	`CMS` -Angabe (z. B. WordPress/TYPO3/Jimdo)	Mittel

18. Anhänge & Vorlagen

- **Anhang A** — Verzeichnis der Verarbeitungstätigkeiten (CSV-als-Text)
- **Anhang B** — DPIA-Formular (mit Beispielen)
- **Anhang C** — Muster-AVV-Klauseln
- **Anhang D** — Muster-Einwilligungstexte (Newsletter, Consent-Banner)
- **Anhang E** — Muster-Datenschutzerklärung (Website)
- **Anhang F** — Muster-Meldung Datenschutzverletzung (Behörde + Betroffene)
- **Anhang G** — Incident-Report-Formular
- **Anhang H** — Muster-Antwortschreiben Betroffenenrechte
- **Anhang I** — Checkliste Drittanbieter/AVV
- **Anhang J** — Checkliste IT-Security/TOM
- **Anhang K** — To-Do-Plan mit Verantwortlichkeiten
- **Anhang L** — Checkliste Website-Datenschutz
- **Anhang M** — Annahmenverzeichnis

- **Anhang N** — 12-Monats-Roadmap
- **Anhang O** — Risiko-Dashboard
- **Anhang P** — Top-5-Sofortmaßnahmen (1-Seiter GF)
- **Anhang Q** — Anleitung „Bericht aktualisieren"
- **Anhang R** — Platzhalter-Verzeichnis

Anhang A — Verzeichnis der Verarbeitungstätigkeiten (VVT)

CSV-Vorlage (kopierfähig; Trennzeichen `;` ; Platzhalter mit echten Werten füllen):

```
Nr;Verarbeitungstaetigkeit;Zweck;Rechtsgrundlage;Betroffenengruppe;Datenkategorien;Empfaenger;Drittland;Loeschfrist;TOM;Verantwortlich
1;Kundenverwaltung/Auftragsabwicklung;Vertragserfuellung;Art.6 I b/c;Kunden;Stamm-,Auftrags-,Rechnungsdaten;Steuerberater,Subunternehmer;{{CLOUD_STANDORT}};8-10 J. (AO/HGB) bzw. 3 J. (BGB);Rollenrechte,Backup,Verschluesselung;GF/Vertrieb
2;Kontaktformular/Interessenten;Anfragebearbeitung;Art.6 I b/f;Interessenten;Name,Firma,Kontakt,Anliegen;-;{{HOSTING_PROVIDER}};nach Erledigung, max 6-12 Mon.;TLS,Zugriffsschutz;Marketing
3;Website-Analyse GA4;Reichweitenanalyse;Art.6 I a (Einwilligung);Website-Besucher;IP,Geraete-/Nutzungsdaten,Cookie-IDs;Google;USA (DPF);GA4-Retention (konfigurierbar);Consent,IP-Kuerzung;Marketing
4;Suchperformance Search Console;SEO;Art.6 I f;Website-Besucher;aggregierte Suchdaten;Google;USA (DPF);Google-seitig;Service-Account;Marketing
5;Beschaeftigtenverwaltung/Lohn;Personal/Lohn;Art.6 I b/c,§26 BDSG,Art.9 II b;Beschaeftigte;Stamm-,Lohn-,Gesundheitsdaten;{{PAYROLL_PROVIDER}},FA,SV;EU;6-10 J. steuer-/sozialrechtl.;Zugriffsbeschr.,Verschluesselung;GF/Personal
6;Bewerbermanagement;Auswahlverfahren;Art.6 I b,§26 BDSG;Bewerber;Bewerbungsdaten;-;EU;6 Mon. nach Absage;Zugriffsschutz,Loeschung;GF/Personal
7;Newsletter/Marketing;Direktwerbung;Art.6 I a;Interessenten/Kunden;E-Mail,Name;{{NEWSLETTER_TOOL}};{{NL_DRITTLAND}};bis Widerruf; Consent dauerhaft;Double-Opt-in,Consent-Log;Marketing
8;Lieferantenverwaltung;Beschaffung;Art.6 I b/f;Lieferanten;Kontakt-,Vertrags-,Zahlungsdaten;Bank;EU;3 J. nach Vertragsende;Zugriffsschutz;Einkauf/Buchhaltung
9;IT-Sicherheit/Server-Logs;Betriebssicherheit;Art.6 I f;Website-Besucher;IP,Zeitstempel;{{HOSTING_PROVIDER}};{{HOST_DRITTLAND}};7-30 Tage;Zugriffsschutz,Loeschautomatik;IT
```

Anhang B — DPIA-Formular (mit Beispielen)

```
DATENSCHUTZ-FOLGENABSCHAETZUNG (Art. 35 DSGVO) - {{COMPANY_NAME}}
1. Verarbeitung: ..................................................
2. Verantwortlicher / DSB: {{DPO_CONTACT}}
3. Zweck(e): ......................................................
4. Datenkategorien / Betroffene: ..................................
5. Notwendigkeit & Verhaeltnismaessigkeit: .........................
6. Risiken fuer Betroffene:
   - Vertraulichkeit (unbefugter Zugriff): .........................
   - Integritaet (Veraenderung): ..................................
   - Verfuegbarkeit (Verlust): ....................................
7. Bewertung: Eintritt (1-3) x Schwere (1-3) = Score:
8. Abhilfemassnahmen (TOM): .......................................
9. Restrisiko: [ ] akzeptabel  [ ] nicht akzeptabel
10. Freigabe (GF/DSB), Datum: .....................................
11. Naechster Review: .............................................

BEISPIEL 1 - Kundenverwaltung: Risiko mittel; Score 4; Massnahmen: Rollenrechte, MFA, Backup,
Verschluesselung; Restrisiko akzeptabel.
BEISPIEL 2 - Ausschreibungs-/Planunterlagen (Auftraggeber-Know-how): i.d.R. kein Personenbezug, aber hohe
Vertraulichkeit; Massnahmen: strenge Zugriffskontrolle, Verschluesselung, NDA; Restrisiko
akzeptabel bei Umsetzung.
BEISPIEL 3 - Fernwartung: Risiko mittel-hoch; Massnahmen: AVV, Zugriff nur nach Freigabe,
Protokollierung, Verschluesselung; Restrisiko akzeptabel.
```

Anhang C — Muster-AVV-Klauseln

> *Textbaustein — vor Verwendung rechtlich prüfen lassen. Platzhalter füllen.*

```
Auftragsverarbeitungsvertrag zwischen {{COMPANY_NAME}} (Auftraggeber) und {{AUFTRAGNEHMER}}.

§1 Gegenstand & Weisungsbindung
Der Auftragnehmer verarbeitet personenbezogene Daten ausschliesslich im Auftrag und nach
dokumentierter Weisung des Auftraggebers (Art. 28 Abs. 3 lit. a DSGVO).

§2 Vertraulichkeit
Es werden nur zur Vertraulichkeit verpflichtete Personen eingesetzt (Art. 28 Abs. 3 lit. b,
Art. 29, 32 Abs. 4).

§3 Technisch-organisatorische Massnahmen
Der Auftragnehmer gewaehrleistet die Sicherheit der Verarbeitung nach Art. 32 (Anlage TOM).

§4 Unterauftragsverarbeiter
Einsatz von Subunternehmern nur mit vorheriger Genehmigung; aktuelle Liste beigefuegt;
Weiterreichung der Pflichten sichergestellt.

§5 Unterstuetzungspflichten
Unterstuetzung bei Betroffenenrechten (Art. 12-23), Datenpannen (Art. 33/34) und DPIA (Art. 35).

§6 Loeschung/Rueckgabe
Nach Beendigung Loeschung oder Rueckgabe nach Wahl des Auftraggebers, sofern keine
Aufbewahrungspflicht besteht.

§7 Nachweise & Kontrolle
Nachweis der Einhaltung; Ermoeglichung von Audits/Inspektionen (Art. 28 Abs. 3 lit. h).

§8 Drittlandtransfer
Uebermittlung in Drittlaender nur auf zulaessiger Grundlage (Angemessenheitsbeschluss/DPF bzw.
Standardvertragsklauseln, Art. 44 ff.).
```

Anhang D — Muster-Einwilligungstexte

> *Textbausteine — rechtlich prüfen lassen. Platzhalter füllen.*

Newsletter (Double-Opt-in):

```
[ ] Ja, ich moechte den Newsletter der {{COMPANY_NAME}} mit Informationen zu Produkten,
Leistungen und Angeboten per E-Mail erhalten. Die Einwilligung kann ich jederzeit mit Wirkung
fuer die Zukunft widerrufen (Abmeldelink in jeder E-Mail oder E-Mail an {{KONTAKT_EMAIL}}).
Hinweise zur Verarbeitung: siehe Datenschutzerklaerung unter {{DSE_URL}}.
```

Consent-Banner (Kurztext):

```
Wir verwenden Cookies und aehnliche Technologien. Notwendige sind fuer den Betrieb erforderlich.
Fuer Statistik/Analyse (z. B. Google Analytics 4) setzen wir Cookies nur mit Ihrer Einwilligung.
Sie koennen frei entscheiden und Ihre Auswahl jederzeit unter "Einstellungen" widerrufen.
[Alle akzeptieren] [Nur notwendige] [Einstellungen]
```

Einwilligung Foto/Referenz (Marketing/Event):

```
Ich willige ein, dass die am {{DATUM_ANLASS}} angefertigten Fotos/Videos zu Marketingzwecken
(Website, Social Media, Print) durch {{COMPANY_NAME}} verwendet werden duerfen. Die Einwilligung
ist freiwillig und jederzeit fuer die Zukunft widerrufbar (Kontakt: {{KONTAKT_EMAIL}}).
```

Anhang E — Muster-Datenschutzerklärung (Website, Grundgerüst)

> *Grundgerüst — auf tatsächlich eingesetzte Dienste anpassen; rechtlich prüfen lassen.*

```
1. Verantwortlicher
{{COMPANY_NAME}}, {{ADRESSE}}, {{KONTAKT_EMAIL}}, {{TELEFON}}. [DSB: {{DPO_CONTACT}}, falls vorhanden]

2. Ihre Rechte
Auskunft, Berichtigung, Loeschung, Einschraenkung, Datenuebertragbarkeit, Widerspruch;
Beschwerderecht bei der Aufsichtsbehoerde (LDA Brandenburg).

3. Server-Logfiles (Art. 6 I f)
Beim Aufruf werden IP-Adresse, Datum/Uhrzeit, abgerufene Datei etc. verarbeitet; Speicherung
{{LOG_RETENTION}} zur Betriebssicherheit. Hosting durch {{HOSTING_PROVIDER}}.

4. Kontaktformular / E-Mail (Art. 6 I b/f)
Verarbeitung zur Bearbeitung der Anfrage; Loeschung nach Erledigung, sofern keine
Aufbewahrungspflicht.

5. Cookies & Einwilligung (§ 25 TDDDG, Art. 6 I a)
Nicht notwendige Cookies/Technologien nur mit Einwilligung; Widerruf jederzeit.

6. Google Analytics 4 (Art. 6 I a)
Nur nach Einwilligung; Anbieter Google Ireland/LLC; Uebermittlung USA moeglich (EU-US Data
Privacy Framework); IP-Kuerzung aktiviert; Speicherdauer {{GA4_RETENTION}}.

7. Weitere Dienste [{{CMS}} / Google Fonts lokal / Maps / reCAPTCHA / {{NEWSLETTER_TOOL}} etc.]
[nur auffuehren, was tatsaechlich eingesetzt wird]

8. Empfaenger / Auftragsverarbeiter
{{HOSTING_PROVIDER}}, IT-Dienstleister, ggf. {{NEWSLETTER_TOOL}} (jeweils mit AVV).

9. Drittlandtransfer
Grundlage DPF/SCC (Art. 44 ff.).

10. Stand: {{DATUM}}
```

Anhang F — Muster-Meldung Datenschutzverletzung

An die Aufsichtsbehörde (Art. 33):

```
Meldung einer Verletzung des Schutzes personenbezogener Daten (Art. 33 DSGVO)
Verantwortlicher: {{COMPANY_NAME}}, {{ADRESSE}}, {{KONTAKT_EMAIL}}
Ansprechpartner: {{ANSPRECHPARTNER}}
1. Zeitpunkt/Zeitraum des Vorfalls und der Kenntnisnahme: ...
2. Art der Verletzung (Vertraulichkeit/Integritaet/Verfuegbarkeit): ...
3. Betroffene Datenkategorien und ungefaehre Anzahl Betroffener/Datensaetze: ...
4. Wahrscheinliche Folgen: ...
5. Ergriffene/vorgeschlagene Massnahmen: ...
6. Wurde >72h ueberschritten? Begruendung: ...
Ort, Datum, Unterschrift
```

An Betroffene (Art. 34):

```
Information ueber eine Verletzung des Schutzes Ihrer personenbezogenen Daten
Sehr geehrte/r ...,
am {{DATUM}} ist es zu [kurze, klare Beschreibung] gekommen. Betroffen sind folgende Daten: ...
Moegliche Folgen: ... Wir haben folgende Massnahmen ergriffen: ...
Empfehlung an Sie: [z. B. Passwort aendern]. Bei Rueckfragen: {{DPO_CONTACT}} / {{KONTAKT_EMAIL}}.
```

Anhang G — Incident-Report-Formular

```
INTERNER DATENPANNEN-REPORT ({{COMPANY_NAME}}) - auch fuer nicht meldepflichtige Vorfaelle
Vorfall-Nr.: ...   Meldende Person: ...   Datum/Uhrzeit Kenntnis: ...
Beschreibung: ...
Betroffene Systeme/Daten/Personen: ...
Risikoeinschaetzung: [ ] kein Risiko [ ] Risiko [ ] hohes Risiko
Meldung Behoerde noetig (72h)? [ ] ja [ ] nein  - erfolgt am: ...
Benachrichtigung Betroffener noetig? [ ] ja [ ] nein - erfolgt am: ...
Sofortmassnahmen: ...   Ursachenanalyse: ...   Folgemassnahmen/TOM-Anpassung: ...
Abschluss/Freigabe (GF/DSB), Datum: ...
```

Anhang H — Muster-Antwortschreiben Betroffenenrechte

Auskunft (Art. 15):

```
Sehr geehrte/r ...,
Bezug nehmend auf Ihren Antrag vom {{DATUM}} teilen wir mit, dass wir folgende Sie betreffende
Daten verarbeiten: [Kategorien, Zwecke, Rechtsgrundlage, Empfaenger, Speicherdauer, Herkunft].
Eine Kopie ist beigefuegt. Sie haben zudem Rechte auf Berichtigung, Loeschung, Einschraenkung,
Widerspruch sowie Beschwerde bei der Aufsichtsbehoerde. Fuer Rueckfragen: {{KONTAKT_EMAIL}}.
Mit freundlichen Gruessen, {{COMPANY_NAME}}
```

Löschung (Art. 17):

```
Sehr geehrte/r ...,
Ihrem Loeschantrag vom {{DATUM}} haben wir entsprochen; Ihre Daten wurden geloescht bzw. gesperrt,
soweit keine gesetzlichen Aufbewahrungspflichten (z. B. steuerrechtlich) entgegenstehen. In diesem
Fall erfolgt die Loeschung nach Fristablauf. Mit freundlichen Gruessen, {{COMPANY_NAME}}
```

Anhang I — Checkliste Drittanbieter/AVV

```
[ ] Alle Dienstleister mit Datenzugriff gelistet
[ ] AVV vorhanden und aktuell (Art. 28)
[ ] TOM-Anlage beigefuegt
[ ] Subunternehmer-Liste geprueft
[ ] Drittlandtransfer-Grundlage (DPF/SCC) dokumentiert
[ ] Audit-/Nachweisrechte vereinbart
[ ] Loesch-/Rueckgaberegelung enthalten
```

Anhang J — Checkliste IT-Security/TOM

```
[ ] Individuelle Benutzerkonten + Rollenrechte
[ ] MFA auf E-Mail/Cloud/Google/GitHub/Buchhaltung
[ ] Passwortmanager, Passwort-Policy
[ ] HTTPS/TLS + HSTS; Geraeteverschluesselung
[ ] Backups (3-2-1) + Wiederherstellungstest
[ ] Automatische Updates (OS/CMS/Plugins/AV)
[ ] Virenschutz/Firewall/Bildschirmsperre
[ ] Logging mit definierter Aufbewahrung
[ ] Physische Sicherung (Serverraum/Akten)
[ ] Notfall-/Wiederanlaufplan
```

Anhang K — To-Do-Plan mit Verantwortlichkeiten

#	Maßnahme	Verantwortlich	Aufwand	Priorität	Frist
1	Consent-Banner (Opt-in) einführen, GA4 daran koppeln	Marketing (David) + Web-Agentur	mittel	Hoch	0–1 Mon.
2	Datenschutzerklärung & Impressum aktualisieren	Marketing + Rechtsprüfung	gering–mittel	Hoch	0–1 Mon.
3	MFA flächendeckend aktivieren	IT	gering	Hoch	0–1 Mon.
4	Datenpannen-Prozess & Register etablieren	GF + IT	gering	Hoch	0–2 Mon.
5	VVT (Art. 30) erstellen	DSB/GF + Prozessverantw.	mittel	Hoch	0–3 Mon.
6	AV-Verträge einholen/prüfen	GF/Einkauf	mittel	Hoch	0–3 Mon.
7	Löschkonzept mit Fristen	DSB/Buchhaltung	mittel	Mittel	3–6 Mon.
8	TOM dokumentieren	IT	mittel	Mittel	3–6 Mon.
9	US-Transfer (DPF) dokumentieren	DSB/Marketing	gering	Mittel	3–6 Mon.
10	Mitarbeiterschulung + Nachweis	GF/DSB	gering	Mittel	3–6 Mon.
11	Prüfung DSB-Benennungspflicht	GF	gering	Mittel	0–2 Mon.
12	Google Fonts lokal hosten (bzw. Matomo prüfen)	Web-Agentur	gering	Niedrig	6–12 Mon.
13	Halbjährliches internes Audit	DSB/GF	gering	laufend	fortlaufend

---

Anhang L — Checkliste Website-Datenschutz

```
[ ] Consent-Tool aktiv (Opt-in, granular, Widerruf, Consent-Log)
[ ] GA4 laedt erst nach Einwilligung; IP-Kuerzung; Retention gesetzt
[ ] Google Tag Manager (falls vorhanden) consent-gesteuert
[ ] Google Fonts lokal gehostet
[ ] Maps/reCAPTCHA/YouTube nur nach Consent (2-Klick)
[ ] Keine Social-Plugins ohne Consent
[ ] Cookie-Inventar (Name/Zweck/Laufzeit/Anbieter) gepflegt
[ ] HTTPS erzwungen + gueltiges Zertifikat + HSTS
[ ] CSP gesetzt
[ ] Datenschutzerklaerung deckt alle aktiven Dienste
[ ] Impressum vollstaendig (§ 5 DDG)
[ ] Kontaktformular: Datensparsamkeit + Datenschutzhinweis + TLS
```

Anhang M — Annahmenverzeichnis

ID	Annahme (`Annahme:`)	Zu bestätigen durch
A1	KMU < 20 Personen mit automatisierter Verarbeitung → keine DSB-Pflicht	GF/Personal (F-12)
A2	Hauptsitz Lübben (Brandenburg) → Aufsichtsbehörde LDA Brandenburg; Niederlassung Wittenburg (MV) → ggf. LfDI M-V	GF
A3	Keine besonderen Kategorien bei Kunden; nur Beschäftigten-AU	Personal
A4	Kein Profiling / keine automatisierte Einzelentscheidung	Marketing/IT
A5	Datenschutzerklärung & Impressum vorhanden, Aktualität unklar	Marketing (F-01)
A6	Buchhaltung/ERP/Cloud-Speicher/Backup vorhanden, Anbieter offen	IT/Buchhaltung (F-02)
A7	HTTPS auf der Website aktiv	Web-Audit (F-01)
A8	Kein Zapier/IFTTT im Einsatz	IT/Marketing
A9	Newsletter nur, falls tatsächlich betrieben	Marketing
A10	Firmierung „Fräsdienst-Service E. Feind GmbH"	GF (Handelsregister)
A11	Hosting/E-Mail/Newsletter in EU	F-04
A12	Beispielwerte „Hetzner/WordPress" NICHT bestätigt (nur Prompt-Beispiele)	F-04/F-13

Anhang N — 12-Monats-Roadmap

Zeitraum	Meilenstein	Verantwortlich
Monat 0–1	Consent-Banner live, DSE/Impressum aktualisiert, MFA aktiv, Datenpannen-Prozess steht	Marketing/IT/GF
Monat 1–3	VVT fertig, AV-Verträge angefordert, DSB-Pflicht geklärt	DSB/GF
Monat 3–6	AVV abgeschlossen, Löschkonzept & TOM dokumentiert, US-Transfer belegt, 1. Schulung	DSB/IT
Monat 6–9	Website-Feinschliff (Fonts lokal/Matomo, CSP), HR-Löschfristen umgesetzt	Web-Agentur/Personal
Monat 9–12	1. internes Audit, KPI-Review, Berichtsupdate an GF	DSB/GF

Anhang O — Risiko-Dashboard

Risiko	Score	Verantwortlich	Frist	Status
R1 GA4 ohne Consent	9	Marketing/IT	0–1 Mon.	offen
R7 Kein Datenpannen-Prozess	6	GF/IT	0–2 Mon.	offen
R11 Kein MFA	6	IT	0–1 Mon.	offen
R2 Fehlende AVV	6	GF	0–3 Mon.	offen
R3 Fehlendes VVT	6	DSB/GF	0–3 Mon.	offen
R4 Veraltete DSE	6	Marketing	0–1 Mon.	offen
R5 US-Transfer undokumentiert	4	DSB	3–6 Mon.	offen
R6 Kein Löschkonzept	4	DSB	3–6 Mon.	offen
R8 TOM undokumentiert	4	IT	3–6 Mon.	offen
R10 Keine Schulung	4	GF	3–6 Mon.	offen
R12 Fehlende Löschfristen HR	4	Personal	3–6 Mon.	offen
R9 Google Fonts extern	2	Web-Agentur	6–12 Mon.	offen

Anhang P — Top-5-Sofortmaßnahmen (1-Seiter für die Geschäftsführung)

```
DATENSCHUTZ - TOP 5 SOFORTMASSNAHMEN ({{COMPANY_NAME}})
1. Cookie-/Consent-Banner mit Opt-in einfuehren - Google Analytics erst nach Zustimmung laden.
   (Verantwortlich: Marketing + Web-Agentur; Frist: 4 Wochen)
2. Datenschutzerklaerung & Impressum aktualisieren.
   (Verantwortlich: Marketing + Rechtspruefung; Frist: 4 Wochen)
3. Zwei-Faktor-Authentifizierung (MFA) fuer alle wichtigen Konten aktivieren.
   (Verantwortlich: IT; Frist: 4 Wochen)
4. Datenpannen-Meldeprozess (72-Stunden-Regel) + Register einfuehren.
   (Verantwortlich: GF/IT; Frist: 6 Wochen)
5. Verzeichnis der Verarbeitungstaetigkeiten (VVT) und AV-Vertraege starten.
   (Verantwortlich: GF/DSB; Frist: 8-12 Wochen)
Rechtlicher Hinweis: Muster vor Einsatz durch Rechtsabteilung/Fachanwalt pruefen lassen.
```

Anhang Q — Anleitung „Bericht aktualisieren"

1. Reale Werte in die Platzhalter einsetzen (Anhang R) — idealerweise über eine `.env` /Config, dann Bericht neu generieren.
2. Offene Fragen (Kap. 17) beantworten → betroffene Annahmen (Anhang M) in **Fakten** überführen (Präfix `Annahme:` entfernen).
3. Nach Live-Website-Audit (F-01) Kap. 12 und Anhang L/E aktualisieren.
4. Bei neuen Tools/Dienstleistern: VVT (Anhang A) und AVV-Liste (Kap. 7) ergänzen.
5. Nach jeder Maßnahme Status im Risiko-Dashboard (Anhang O) und To-Do-Plan (Anhang K) pflegen.
6. Versionsnummer/Datum im Kopf erhöhen; Änderungsvermerk führen.
7. Mindestens jährlich vollständigen Review (Kap. 15).

Anhang R — Platzhalter-Verzeichnis

> Die Spalte „Quelle" nennt den zugehörigen Schlüssel in der `.env` -Vorlage (`.env.example` , Repository-Wurzel) bzw. „manuell", wenn der Wert direkt einzutragen ist.

Platzhalter	Bedeutung	Quelle (`.env` /manuell)
`{{COMPANY_NAME}}`	Firmierung des Verantwortlichen	manuell / Handelsregister
`{{ADRESSE}}`	Anschrift	manuell
`{{GESCHAEFTSFUEHRER}}`	Geschäftsführer	manuell
`{{KONTAKT_EMAIL}}` / `{{TELEFON}}`	Kontaktdaten	manuell
`{{USt-IdNr}}`	Umsatzsteuer-ID	manuell
`{{DPO_CONTACT}}`	DSB-Kontakt (falls vorhanden)	manuell
`{{HOSTING_PROVIDER}}`	Hosting-Anbieter	`HOSTING_PROVIDER`
`{{HOST_DRITTLAND}}`	Serverstandort/Drittland Hosting	abgeleitet aus Hoster
`{{CMS}}`	Content-Management-System	`CMS`
`{{NEWSLETTER_TOOL}}`	Newsletter-Anbieter	`NEWSLETTER_TOOL`
`{{NL_DRITTLAND}}`	Drittland Newsletter	abgeleitet
`{{PAYROLL_PROVIDER}}`	Lohnabrechnung	`PAYROLL_PROVIDER`
`{{PAYMENT_PROVIDER}}`	Zahlungsdienstleister	`PAYMENT_PROVIDER`
`{{IT_SUPPORT}}`	IT-Dienstleister	manuell
`{{AUFTRAGNEHMER}}`	AVV-Vertragspartner	je Vertrag
`{{CLOUD_STANDORT}}`	Cloud-Speicher-Standort	abgeleitet
`{{LOG_RETENTION}}` / `{{GA4_RETENTION}}`	Aufbewahrungsdauer Logs/GA4	Konfiguration
`{{DSE_URL}}` / `{{DATUM}}` / `{{DATUM_ANLASS}}`	URL/Datumsangaben	manuell
`{{KACHELANBIETER}}` / `{{KACHEL_HOST}}` / `{{KACHEL_DATENSCHUTZ_URL}}`	Kachelanbieter der Cockpit-Straßenkarte (Abschnitt 12.1)	Admin › Funktionen und Quellen im Cockpit

---

Transparenz — Annahmen, Quellen, Aktualisierung

Alle Annahmen sind mit `Annahme:` gekennzeichnet und in **Anhang M** zusammengefasst. **Offene Fragen** sind mit `Offene Frage:` bzw. F-Nummern gekennzeichnet und in **Kap. 17** priorisiert (4-spaltig).

Quellen: (1) Interne Codebasis `dhalko-feind/AIassistent` (`config.example.yaml` , `docs/SPEC.md` , `docs/SETUP.md` , `data/crm/leads.example.csv`) als verifizierte Faktenbasis; (2) geltendes Recht: DSGVO, BDSG, TDDDG (vormals TTDSG), ePrivacy-Richtlinie, AO/HGB; (3) EU-US Data Privacy Framework

(Angemessenheitsbeschluss 10.07.2023); (4) allgemeine KMU-/Branchenpraxis. Es wurde **keine** externe Live-Recherche durchgeführt (Netzwerk gesperrt).

Aktualisierung: siehe Anhang Q. Bei Nachlieferung realer Werte (`.env` /Config) kann der Bericht automatisiert neu erzeugt und Annahmen in Fakten überführt werden.

Ende des Berichts — Version 1.5 (Entwurf), 28.10.2026. Streng vertraulich. Vor rechtsverbindlichem Einsatz der Vorlagen: Prüfung durch Rechtsabteilung / Fachanwalt für IT-Recht.

---

1. EU-US Data Privacy Framework — Angemessenheitsbeschluss der EU-Kommission vom 10.07.2023; nach Art. 45 DSGVO gelten zertifizierte US-Unternehmen (u. a. Google LLC) als sicheres Drittland. SCC (Art. 46) als Auffanglösung. ↩

2. LG München I, Urteil vom 20.01.2022 (Az. 3 O 17493/20): das dynamische Nachladen von Google Fonts von Google-Servern ohne Einwilligung verletzt das allgemeine Persönlichkeitsrecht (IP-Übermittlung). Empfehlung: Schriften lokal einbinden. ↩

3. § 25 TDDDG (Telekommunikation-Digitale-Dienste-Datenschutz-Gesetz, in Kraft seit 14.05.2024; zuvor § 25 TTDSG) verlangt eine Einwilligung für das Speichern/Auslesen von Informationen auf Endgeräten (Cookies, Tracking), sofern nicht unbedingt erforderlich. ↩